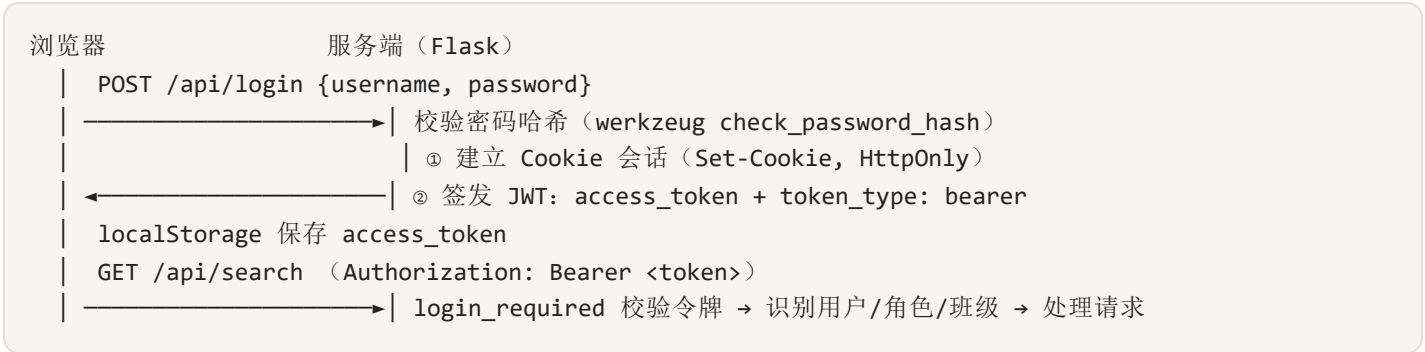


身份认证与知识库问答的实现方案

0930 课后任务：结合 CampusClaw 仓库现有代码，梳理基于 Token 的身份认证与基于知识库问答的实现方案。文中所有机制均对应仓库中的真实实现，括注了所在文件。

一、基于 Token 的身份认证

1. 总体流程



系统采用**双凭证并存**：Cookie 会话服务于页面导航（SSR），Bearer Token 服务于 API 调用。二者等价，Bearer 优先。

2. 令牌格式与签发（`app/token_auth.py`）

- 采用 **JWT (HS256)**，标准库 `hmac / hashlib / base64 / json` 实现，无新增依赖。
- Payload 声明：`sub`（用户 ID）、`username`、`role`（teacher/student）、`class_id`、`iat`（签发时间）、`exp`（过期时间 = 签发后 2 小时）。
- 签名密钥复用服务端环境变量 `SECRET_KEY`，**不硬编码、不下发**。
- 签发位置：`POST /api/login` 成功分支（`app/auth.py` 的 `api_login`），与建立会话同时进行；响应体含 `access_token` 与 `token_type: "bearer"`。

3. 令牌校验（`app/auth.py` 的 `login_required`）

每个受保护接口的前置装饰器按以下顺序判定：

1. 请求头含 `Authorization: Bearer <token>` → `verify_token` 校验**签名与 exp**；通过则把声明写入请求上下文（Flask `g`），失败一律返回 **401**（签名篡改、格式错误、过期不区分，防探测）。
2. 无 Bearer 头 → 回退到既有 Cookie 会话判定；API 未登录返回 401，页面请求 302 到登录页。

视图统一经 `current_user()` 读取身份——**角色与班级只可能来自已验证的凭证**（令牌声明或会话），请求 query/body 中携带的 `class_id` 一律丢弃，伪造班级参数无法改变数据边界。

4. 前端携带（`app/templates/login.html`、`app/templates/materials.html`）

- 登录页 fetch /api/login 成功后，把 access_token 存入 localStorage (键 campusclaw_token) 再跳转。
- 材料页封装 authFetch()：所有 API 调用 (检索 /api/search、问答 /api/ask) 自动附加 Authorization: Bearer <token>；无令牌时退化为普通 fetch (Cookie 仍可用)。
- 令牌只出现在 Authorization 头，不出现在 URL 查询串 (避免落入日志与浏览器历史)；退出登录时清除 localStorage。

5. 验证方式

- 自动化测试 (tests/test_lesson4.py 中 TokenAuthTest / TokenAccessTest 共 7 项)：登录响应含合法三段式 JWT 且 payload 含 role/class_id/exp；无 Cookie 仅凭 Bearer 检索返回 200；篡改签名、过期令牌、非法头均 401；持 A 班令牌伪造 B 班参数仍按 A 班过滤 (200 空命中)。
- 手动验证：DevTools 网络面板可见 search/ask 请求头中的 Authorization: Bearer eyJ...。

二、基于知识库的问答

1. 总体架构

入库与检索问答分离，正文存关系库 (SQLite)，向量存向量库 (Qdrant)，两者以同一主键关联：

上传 (仅教师) → 解析正文 → 切分 → knowledge_chunks (SQLite) + FTS5 索引
└─ 嵌入网关 (OpenAI 兼容) → Qdrant (向量主键 = 切片主键)

提问 → 本班混合检索 (keyword + vector, RRF 融合) → 有命中 → 对话网关生成带 [1] 标注的简短回答
└─ 无命中 → 固定文案，不调用模型

2. 入库链路

1. 切分 (app/chunking.py)：正文按策略切为切片。 auto (默认，约 800 字、重叠 80 字，优先在句号/换行/空行断开)、 custom (自定义分隔符，100–2000 字、重叠 0–50%)、 hierarchy (按 Markdown 标题分章)。预处理只作用于待切分文本， knowledge_entries.body_text 保留上传原文。
2. 切片入库 (app/db.py)： knowledge_chunks 记录切片文本、序号、字符区间、班级、 index_status；同步写入 FTS5 trigram 全文索引 (中文按三字滑窗切分，短词降级 LIKE 子串匹配；无空格长问句按滑窗二字词扩展)。
3. 嵌入与向量入库 (app/embedding.py、 app/vectorstore.py)：服务端调用 OpenAI 兼容嵌入网关，向量写入 Qdrant 集合 campusclaw_chunks (余弦度量)。向量主键 = knowledge_chunks.id = payload.chunk_id，payload 只存 class_id 等标识、不含正文。嵌入失败时材料与切片保留，切片标记 failed，不写不完整的向量。

3. 三种检索模式 (app/retrieval.py， GET /api/search)

模式	访问组件	排序
keyword	仅 SQLite FTS5 (短词 LIKE 兜底)，不调用嵌入、不访问 Qdrant	全文相关度 (bm25)

模式	访问组件	排序
vector	问句嵌入 → Qdrant 按 <code>class_id</code> 过滤 → 余弦 < 0.35 丢弃 → 回表取正文并再核对班级	余弦相似度
hybrid (默认)	两路均执行、各自过滤	RRF (k=60) 按名次融合 ，缺席一路不贡献分数

每条命中含材料标题、切片序号、字符区间与摘录（摘录取自 SQLite 的 `chunk_text`，而非向量库），可回溯到原文。

4. 问答链路（`app/search.py` 的 `POST /api/ask`）

- 1. 仅以用户最新一句做**本班混合检索**，取前 4 条切片。
- 2. **无命中** → 直接返回固定文案「资料中未找到相关内容」，`citations` 为空，**不调用生成模型**（防止模型凭参数记忆编造天气、比分类答案）。
- 3. **有命中** → 对话模块（`app/chat.py`）收到材料标题、切片序号、切片正文与本轮提问；system 提示由服务端写入（仅允许依据编号资料作答），**客户端注入的 system 消息被丢弃**；不给模型向量分量与他班切片。
- 4. 回答中以 `[1]`、`[2]` 标注出处，编号顺序与 `citations` 列表一致。

5. 班级隔离与故障降级

- 班级标识只取自已验证凭证（会话或令牌声明）：关键字与向量两条路径都带 `class_id = 会话班级` 过滤，向量命中后**回表再次核对班级**——单侧过滤不构成隔离。
- 跨班检索对外表现为 **HTTP 200 + 空命中**，不以 403/404 泄露资料归属。
- Qdrant 或嵌入服务不可用时：`keyword` 正常，`vector / hybrid` 返回 **503 且不编造分数**，问答退化为固定文案；空查询返回 400。

6. 部署拓扑（`docker-compose.yml`）

```
浏览器 → web(Nginx, 8088 唯一对外端口) → app(Flask/gunicorn, 无端口映射)
                                     ↳ qdrant(向量库, 无端口映射, 卷持久化)
                                     ↳ 嵌入/对话网关(出站, 密钥仅 .env)
```

向量库与两类模型网关都不是浏览器入口；密钥只存服务端环境变量。

7. 验证方式

- 自动化测试 37 项全部通过（`python tests/test_lesson4.py`）：切分三种策略、关键字命中含出处、跨班 200 空命中、伪造 `class_id` 被丢弃、无命中不调模型（断言对话网关调用计数为零）、有命中才生成且 `[1]` 与 `citations` 对齐、两库主键一致性与 payload 不含正文、Qdrant 停机后的降级行为。
- Compose 端到端实证：经 8088 登录→三种检索→问答全通；宿主直连 qdrant (6333) 与 app (8000) 均失败；`down / up` 后数据与向量仍在。

附：关键代码索引

主题	文件
JWT 签发/校验	app/token_auth.py
登录接口、双凭证装饰器	app/auth.py
检索三种模式与 RRF 融合	app/retrieval.py
切分策略	app/chunking.py
嵌入/对话网关调用	app/embedding.py 、 app/chat.py
Qdrant 客户端	app/vectorstore.py
问答接口与重建索引	app/search.py
切片表与全文索引	app/db.py
前端令牌携带与问答面板	app/templates/login.html 、 app/templates/materials.html
自动化测试	tests/test_lesson4.py